

HƯỚNG DẪN TEST API BẰNG POSTMAN

Dành cho tester mới bắt đầu - không cần biết lập trình

SERVER API QUẢN LÝ CỬA HÀNG ĐIỆN THOẠI

Production: thaotesting-git-main-minhdubai.vercel.app

Phiên bản tài liệu: 11/07/2026

Bạn sẽ làm được gì sau tài liệu này?

Bạn sẽ tự gửi request tới server, đăng nhập, dùng token, kiểm tra dữ liệu, tạo dữ liệu thử và nhận biết lỗi mà không cần viết code.

Nguyên tắc an toàn

Đây là server production dùng chung. Chỉ tạo dữ liệu có tiền tố TEST_, ghi lại ID đã tạo, không xóa hoặc sửa dữ liệu của người khác. API xóa sản phẩm thực tế chỉ đánh dấu sản phẩm không còn hoạt động.

Mục lục

1. API và Postman là gì?
2. Chuẩn bị Postman và Environment
3. Bài 1 - Kiểm tra server
4. Bài 2 - Đăng nhập và lưu token
5. Bài 3 - Gọi API cần đăng nhập
6. Bài 4 - Xem và tạo dữ liệu
7. Bài 5 - Tạo đơn hàng
8. Kiểm thử lỗi và quyền
9. Danh mục API
10. Checklist báo lỗi

Cách đọc nhanh

Làm lần lượt các bài 1 đến 5. Mỗi bài đều có: thao tác trong Postman, dữ liệu mẫu, kết quả mong đợi và lỗi thường gặp.

1. Hiểu nhanh: API và Postman

API giống như quầy tiếp nhận yêu cầu. Bạn gửi một yêu cầu (request), server xử lý rồi trả kết quả (response). Postman là công cụ giúp bạn tạo và gửi yêu cầu đó bằng giao diện.

Bốn phần cần nhớ

Thao tác	Method + URL	Mục đích
Method	GET / POST / PATCH / DELETE	Hành động: xem, tạo, sửa hoặc xóa.
URL	{{baseUrl}}/api/products	Địa chỉ nơi nhận request.
Headers	Authorization, Content-Type	Thông tin đi kèm, như vé đăng nhập.
Body	JSON	Dữ liệu gửi lên khi tạo hoặc sửa.

Ý nghĩa Method

GET: lấy/xem dữ liệu. POST: tạo mới hoặc đăng nhập. PATCH: sửa một phần dữ liệu. DELETE: xóa hoặc vô hiệu hóa.

Kết quả quan trọng nhất

Nhìn vào Status và phần JSON trong Body. Status 2xx thường là thành công; 4xx thường là request hoặc quyền có vấn đề; 5xx thường là lỗi phía server.

Cấu trúc response chung

```
{
  "success": true,
  "message": "Product created",
  "data": { "product": {} }
}
```

2. Chuẩn bị Postman

Cài và mở Postman. Bạn có thể dùng bản desktop hoặc web. Tạo một Collection mới tên Cellphone Store API.

Tạo Environment

1. Chọn Environments ở thanh bên trái, bấm dấu +.
2. Đặt tên: Cellphone Store - Production.
3. Thêm hai biến dưới đây. Với token, để trống lúc đầu.

Thao tác	Method + URL	Mục đích
baseUrl	https://thaotesting-git-main-minhdubai.vercel.app	Địa chỉ server production.
token	để trống	JWT nhận được sau khi login.

4. Bấm Save, rồi chọn environment này ở góc trên bên phải.

Dấu hiệu làm đúng

Khi rê chuột lên {{baseUrl}} trong URL request, Postman hiển thị địa chỉ production. Nếu biến có màu đỏ hoặc không có giá trị, hãy kiểm tra đã Save và chọn đúng Environment chưa.

Thiết lập request JSON

Với POST/PATCH: mở tab Body → chọn raw → chọn JSON. Postman sẽ tự thêm header Content-Type: application/json.

Không chia sẻ token

Token tương đương vé đăng nhập. Không chụp màn hình hoặc gửi token lên nhóm công khai. Nếu token hết hạn, đăng nhập lại và thay giá trị token.

3. Bài 1 - Kiểm tra server

Mục tiêu: xác nhận server đang phản hồi trước khi test các chức năng khác.

Thao tác

1. Trong Collection, bấm Add request, đặt tên 01 - Health check.
2. Chọn Method GET.
3. Nhập URL rồi bấm Send:

```
{{baseUrl}}/health
```

Kết quả mong đợi

Status thuộc nhóm 2xx và response cho biết server đang hoạt động. Request này không cần token và không có Body.

Nếu không gọi được

Kiểm tra Internet, URL không có dấu cách, đã chọn đúng Environment và biến baseUrl có giá trị. Nếu thấy 404, kiểm tra đường dẫn chính xác là /health, không phải /api/health.

Ghi nhận bằng chứng

Chụp màn hình gồm Method, URL, Status, thời gian phản hồi và Body. Ghi thời điểm test vì lỗi kết nối có thể chỉ xảy ra tạm thời.

4. Bài 2 - Đăng nhập và lưu token

Dùng tài khoản mẫu đã được seed. Theo README, mật khẩu mặc định của các user mẫu là secret123. Email cụ thể cần lấy từ người quản trị dữ liệu test hoặc Swagger/dữ liệu seed.

Tạo request Login

Method: POST

```
{{baseUrl}}/api/login
```

Body → raw → JSON:

```
{
  "email": "EMAIL_TAI_KHOAN_TEST",
  "password": "secret123"
}
```

Bấm Send. Response thành công có success: true và chứa JWT. Tên trường token có thể xem trực tiếp trong data của response.

Lưu token - cách dễ nhất

Copy chuỗi token (không copy dấu ngoặc kép) → mở Environment → dán vào giá trị biến token → Save.

Lưu token tự động - tùy chọn

Trong tab Scripts → Post-response, dùng đoạn sau. Script thử các vị trí phổ biến của token:

```
const json = pm.response.json();
const token = json.data?.token || json.data?.accessToken || json.token;
if (token) pm.environment.set("token", token);
```

Kiểm tra

Sau khi Send, mở Environment và xác nhận biến token đã có chuỗi dài. Nếu chưa có, xem response để xác định đúng tên trường rồi copy thủ công.

5. Bài 3 - Gọi API cần đăng nhập

Mục tiêu: kiểm tra token hoạt động và xem thông tin tài khoản hiện tại.

Tạo request GET /api/me

```
{{baseUrl}}/api/me
```

Mở tab Authorization → Type: Bearer Token → Token: {{token}} → Send.

Kết quả mong đợi

Status 2xx; response cho biết user đang đăng nhập. Kiểm tra email và roles có đúng với tài khoản test.

Áp dụng token cho cả Collection

Mở Collection → Authorization → chọn Bearer Token → nhập {{token}} → Save. Các request con chọn Inherit auth from parent.

Lỗi 401

Thường do thiếu token, token bị copy thừa dấu ngoặc kép/khoảng trắng, token hết hạn hoặc dùng sai Environment. Login lại, lưu token mới và thử lại.

Lỗi 403

Bạn đã đăng nhập nhưng vai trò không có quyền thực hiện hành động. Đây khác với 401. Hãy ghi lại role, Method, URL và response để báo lỗi hoặc xác nhận đúng phân quyền.

Bài kiểm tra nhanh

Gửi cùng request ba lần: có token hợp lệ, bỏ token, và thay token bằng chữ abc. Kỳ vọng lần đầu thành công; hai lần sau bị từ chối.

6. Bài 4 - Xem và tạo dữ liệu

Bắt đầu bằng GET để lấy ID thật, sau đó mới POST/PATCH. Không tự chế UUID vì các quan hệ phải tồn tại.

Xem danh sách sản phẩm

```
GET {{baseUrl}}/api/products
```

Authorization kế thừa từ Collection. Không có Body. Kiểm tra success, danh sách sản phẩm và các trường như id, sku, name, price, unitsInStock, isActive.

Tạo khách hàng test

```
POST {{baseUrl}}/api/customers
```

Body:

```
{
  "name": "TEST_Nguyen Van A",
  "phone": "0900000001",
  "email": "test.nguyenvana@example.com",
  "address": "123 Duong Test, TP HCM"
}
```

Sau khi thành công, copy id của customer từ response. Tạo biến Environment tên customerId để dùng lại.

Sửa khách hàng

```
PATCH {{baseUrl}}/api/customers/{{customerId}}
```

Body:

```
{
  "phone": "0900000099",
  "address": "456 Duong Test Moi, TP HCM"
}
```

Kết quả cần kiểm tra

Response báo thành công; GET /api/customers trả về đúng dữ liệu mới; các trường không gửi trong PATCH vẫn giữ nguyên.

7. Bài 5 - Tạo đơn hàng

Đây là luồng có nhiều quan hệ. Trước tiên dùng các API GET để lấy ID thật: customer, employee, delivery company và product đang hoạt động/còn hàng.

Thao tác	Method + URL	Mục đích
Khách hàng	GET {{baseUrl}}/api/customers	Lấy customerId.
Nhân viên	GET {{baseUrl}}/api/employees	Lấy employeeId.
Đơn vị giao	GET {{baseUrl}}/api/delivery-companies	Lấy deliveryCompanyId.
Sản phẩm	GET {{baseUrl}}/api/products	Lấy productId và giá.

Request tạo đơn

POST {{baseUrl}}/api/orders

```
{
  "customerId": "UUID_KHACH_HANG",
  "employeeId": "UUID_NHAN_VIEN",
  "deliveryCompanyId": "UUID_DON_VI_GIAO",
  "requiredDate": "2026-07-20",
  "freight": 3.5,
  "shipName": "TEST_Nguyen Van A",
  "shipAddress": "123 Duong Test",
  "shipCity": "Ho Chi Minh City",
  "shipCountry": "Vietnam",
  "items": [{
    "productId": "UUID_SAN_PHAM",
    "quantity": 1,
    "discount": 0.1
  }]
}
```

Không bắt buộc gửi unitPrice; nếu bỏ qua, server dùng giá hiện tại của sản phẩm. discount từ 0 đến 1; ví dụ 0.1 là giảm 10%.

7.1 Kiểm tra kết quả đơn hàng

Sau khi tạo thành công, ghi lại order ID và kiểm tra ít nhất các điểm sau:

- Đơn gắn đúng customer, employee, delivery company.
- Có đúng số dòng items và quantity.
- Giá/discount đúng quy ước.
- Tồn kho thay đổi hợp lý nếu nghiệp vụ có trừ kho.
- GET /api/orders tìm thấy đơn vừa tạo.

Cập nhật trạng thái

```
PATCH {{baseUrl}}/api/orders/ORDER_ID/status
```

```
{
  "status": "completed"
}
```

Chỉ dùng một trong ba giá trị: pending, completed, cancelled.

Ca âm quan trọng

Thử items rỗng; quantity = 0; discount = 1.5; UUID không tồn tại; status = done. Server phải từ chối và trả message/errors đủ rõ để biết trường nào sai.

Điều chỉnh tồn kho - chỉ khi được phép

```
POST {{baseUrl}}/api/inventory/adjustments
```

```
{
  "productId": "UUID_SAN_PHAM",
  "type": "in",
  "quantity": 10,
  "note": "TEST_Nhap kho bang Postman"
}
```

type = in để nhập thêm; out để xuất thủ công; audit để đặt tồn kho về một con số chính xác. Audit có tác động lớn, chỉ dùng với dữ liệu test được chỉ định.

8. Kiểm thử lỗi và phân quyền

Một tester tốt không chỉ kiểm tra đường đi đúng. Hãy thay đổi từng yếu tố một để biết chính xác nguyên nhân.

Thao tác	Method + URL	Mục đích
Thiếu dữ liệu	Bỏ email/name/items	Kỳ vọng validation chỉ rõ trường bắt buộc.
Sai định dạng	Email = abc; UUID = 123	Kỳ vọng 4xx, không tạo dữ liệu.
Sai biên	quantity = 0; stock = -1	Kỳ vọng bị từ chối.
Trùng dữ liệu	SKU/email/category name đã có	Kỳ vọng báo trùng rõ ràng.
Thiếu đăng nhập	Bỏ Authorization	Kỳ vọng 401.
Thiếu quyền	staff gọi API admin	Kỳ vọng 403.
Không tồn tại	UUID hợp lệ nhưng không có	Kỳ vọng 404 hoặc lỗi nghiệp vụ rõ ràng.

Cách đọc errors

```
{
  "success": false,
  "message": "Validation failed",
  "errors": {
    "items[0].quantity": ["Quantity must be an integer greater than zero."],
    "customerId": ["Customer does not exist."]
  }
}
```

Ở ví dụ trên, dòng hàng đầu tiên có quantity sai và customerId không tồn tại. Sửa đúng hai trường đó rồi gửi lại.

Mỗi lần chỉ đổi một biến

Nếu vừa đổi token, Body và URL cùng lúc, bạn sẽ khó biết yếu tố nào gây lỗi. Hãy tạo Duplicate request trước khi thử ca âm.

9. Danh mục API nhanh

Thao tác	Method + URL	Mục đích
Health	GET /health	Công khai, kiểm tra server.
Auth	POST /api/signup; POST /api/login	Tạo tài khoản, đăng nhập.
User	GET /api/me; /user-area	Kiểm tra user/token.
Role	GET /api/admin-area; /manager-area	Kiểm tra phân quyền.
Categories	GET; POST /api/categories	Xem và tạo danh mục.
Categories	PATCH /api/categories/:id	Sửa danh mục.
Suppliers	GET; POST /api/suppliers	Xem và tạo nhà cung cấp.
Suppliers	PATCH /api/suppliers/:id	Sửa nhà cung cấp.
Delivery	GET; POST /api/delivery-companies	Xem và tạo đơn vị giao.
Delivery	PATCH /api/delivery-companies/:id	Sửa đơn vị giao.
Employees	GET; POST /api/employees	Xem và tạo nhân viên.
Employees	PATCH /api/employees/:id	Sửa nhân viên.

9. Danh mục API nhanh - tiếp

Thao tác	Method + URL	Mục đích
Products	GET; POST /api/products	Xem và tạo sản phẩm.
Products	PATCH; DELETE /api/products/:id	Sửa hoặc vô hiệu hóa.
Inventory	GET /api/inventory	Xem tồn kho.
Inventory	POST /api/inventory/adjustments	Điều chỉnh tồn kho.
Customers	GET; POST /api/customers	Xem và tạo khách hàng.
Customers	PATCH /api/customers/:id	Sửa khách hàng.
Orders	GET; POST /api/orders	Xem và tạo đơn.
Orders	PATCH /api/orders/:id/status	Đổi trạng thái đơn.
Users	PATCH /api/users/:id/roles	Admin đổi roles.

Swagger

Tài liệu tương tác production: <https://thaotesting-git-main-minhdubai.vercel.app/api-docs>

OpenAPI JSON: <https://thaotesting-git-main-minhdubai.vercel.app/api-docs.json>

Quyền mặc định

admin: toàn quyền, gồm đổi role user. manager: quản lý sản phẩm, danh mục, nhà cung cấp, tồn kho, khách hàng, giao hàng, nhân viên, đơn hàng. staff: đọc dữ liệu chính và tạo khách hàng/đơn hàng. user: quyền cơ bản theo cấu hình server.

10. Checklist trước khi báo lỗi

- ☐ Đã chọn đúng Environment.
- ☐ Method và URL chính xác.
- ☐ Request cần đăng nhập đã có Bearer Token.
- ☐ Body chọn raw + JSON, dấu ngoặc và dấu phẩy hợp lệ.
- ☐ ID dùng trong URL/Body là ID thật và đúng loại dữ liệu.
- ☐ Có thể lặp lại lỗi ít nhất hai lần.
- ☐ Đã thử lại bằng request tối giản hoặc tài khoản đúng quyền.
- ☐ Không để lộ token/mật khẩu trong ảnh báo lỗi.

Mẫu nội dung bug report

Tiêu đề: [API][Orders] Không báo lỗi khi quantity = 0
Môi trường: Production - 11/07/2026 10:30 GMT+7
Tài khoản/role: tester.staff@example.com / staff
Method + URL: POST {{baseUrl}}/api/orders
Điều kiện trước: token hợp lệ, các ID tồn tại
Bước thực hiện: 1... 2... 3...
Kết quả thực tế: Status..., response...
Kết quả mong đợi: Từ chối và báo quantity > 0
Tần suất: 3/3
Đính kèm: Postman request/response đã che token

Mẹo chụp bằng chứng

Mở Postman Console nếu cần xem request thực tế. Che Authorization, password và token. Giữ lại request body, status, response body, thời gian và correlation/request ID nếu server trả về.

Nguồn tài liệu

Nội dung được biên soạn từ README.md của dự án Manual Auth Supabase Node Backend tại thời điểm 11/07/2026. Khi hành vi thực tế khác tài liệu, ưu tiên ghi nhận bằng chứng từ response và đối chiếu Swagger/OpenAPI hiện hành.

Bạn đã sẵn sàng: Health → Login → Token → GET → POST/PATCH → Negative test